

Autenticação Contextual Autônoma para Aplicações Web Combinando um Ensemble de IA e Auditoria em Blockchain Permissionada

João Guedes de Brito

Programa de Pós-Graduação em Engenharia de Sistemas e Produtos (PPGESP)

Instituto Federal da Bahia (IFBA)

Salvador, Bahia, Brasil

joaoguedesdebrito@gmail.com

Cleber Jorge Lira de Santana

Programa de Pós-Graduação em Engenharia de Sistemas e Produtos (PPGESP)

Instituto Federal da Bahia (IFBA)

Salvador, Bahia, Brasil

cleberlira@ifba.edu.br

Resumo—Mecanismos tradicionais de autenticação baseados em senhas estáticas ou em autenticação multifator (MFA) fixa permanecem amplamente adotados, mas ignoram o contexto comportamental e ambiental de cada tentativa de acesso e são cada vez mais explorados por ataques de *credential stuffing*, phishing e tomada de conta. Este artigo apresenta um sistema autônomo de autenticação contextual para aplicações web que combina um ensemble de aprendizado de máquina com auditoria em blockchain permissionada. Cada login é descrito por quatorze critérios contextuais e comportamentais, avaliados por um ensemble de Isolation Forest, Random Forest e uma rede neural multicamada; o escore de risco resultante conduz uma decisão adaptativa em três faixas (permitir, reforçar com MFA ou bloquear). Propõe-se ainda uma camada de auditoria em que cada decisão, com o escore e os critérios que a justificaram, é registrada em uma rede Hyperledger Fabric; discute-se quando essa escolha se justifica frente a logs assinados e bancos append-only. Nesta fase, a camada de auditoria é um projeto: o protótipo persiste as decisões em um banco relacional e a integração com o Fabric ainda não foi realizada, de modo que nenhuma propriedade de imutabilidade é reivindicada. Em avaliação *offline* sobre um conjunto de dados sintéticos com cerca de 50.000 registros de login (95% legítimos, 5% suspeitos), o ensemble alcançou 98,1% de acurácia, 80,2% de F1-score e AUC-ROC de 0,99 no conjunto de teste, com taxa de falsos positivos de 0,8% no limiar binário escolhido e latência de inferência de aproximadamente 33 ms por requisição; com as três faixas, 7,3% dos ataques passam sem desafio e 2,7% dos acessos legítimos sofrem atrito. O ensemble supera cada modelo isolado em cerca de 3 pontos de F1, mas um atacante que imita apenas os critérios de horário e ritmo reduz o recall de 77,6% para 50,7%, e com um proxy residencial, para 18,0%. Os rótulos provêm do próprio gerador sintético; os resultados caracterizam, portanto, a viabilidade do pipeline, e não desempenho esperado em produção.

Index Terms—autenticação contextual, autenticação baseada em risco, aprendizado de máquina, ensemble, detecção de anomalias, blockchain, trilha de auditoria, segurança da informação.

I. INTRODUÇÃO

A autenticação é a primeira linha de defesa de aplicações web. Historicamente, apoiou-se em um fator de conhecimento — a senha —, cujas fragilidades são amplamente documentadas: senhas são reutilizadas entre serviços, vazadas em larga escala e exploradas por força bruta, *credential stuffing* e phishing [1], [2]. A autenticação multifator (MFA) mitiga parte dessa exposição ao combinar fatores de conhecimento, posse e inerência, mas a MFA estática ainda sucumbe a engenharia social, troca de chip (SIM swapping) e interceptação de códigos em tempo real, além de introduzir atrito na experiência do usuário [1].

A escala do problema justifica ir além da credencial. Credential stuffing, phishing e o uso de credenciais roubadas seguem entre os principais vetores em relatórios de incidentes, e a fraude por tomada de conta impõe custos financeiros e reputacionais diretos a organizações e usuários finais [2]. A reutilização de senhas transforma qualquer vazamento isolado em um passivo entre serviços, enquanto ferramentas de ataque comoditizadas tornam o abuso de login em larga escala barato e altamente automatizado. Sobretudo, defesas estáticas — políticas de robustez de senha e códigos de uso único — não observam *como*, *quando* ou *de onde* ocorre um login e, portanto, não distinguem um usuário legítimo de um adversário que já detém credenciais válidas. Marcos regulatórios como a LGPD [21] acrescentam um requisito adicional: decisões automatizadas de acesso sobre dados pessoais precisam ser comprovadamente auditáveis. Em conjunto, essas pressões motivam decisões de autenticação condicionadas ao contexto completo de cada tentativa — e que deixem uma trilha verificável do *porquê* de cada decisão.

Para enfrentar essas limitações, as diretrizes de identidade digital do NIST e o modelo de Zero Trust recomendam

mecanismos *adaptativos*, nos quais o nível de verificação exigido é proporcional ao risco estimado de cada tentativa [1], [3]. Isso desloca a autenticação de uma decisão binária e estática para uma avaliação contínua e sensível ao contexto — abordagem conhecida na literatura como autenticação baseada em risco (*Risk-Based Authentication*, RBA). Estudos empíricos de serviços em produção mostram, contudo, que o RBA implantado é dominado por um único sinal (tipicamente o endereço IP) e por heurísticas ajustadas manualmente [4], [5]. Em paralelo, quando as decisões de acesso são delegadas a modelos autônomos, elas precisam ser *auditáveis* por terceiros (por exemplo, em fiscalizações de conformidade), requisito que registros de decisão sob a guarda de um único operador não atendem plenamente.

Este artigo propõe um sistema autônomo de autenticação contextual que acopla uma decisão adaptativa por aprendizado de máquina (ML) ao seu registro para auditoria. As principais contribuições são:

- uma arquitetura ponta a ponta que funde quatorze critérios contextuais e comportamentais em um único escore de risco calculado por um ensemble de Isolation Forest, Random Forest e rede neural, conduzindo uma decisão adaptativa em três faixas;
- o projeto de uma camada de auditoria em blockchain permissionada acoplada à decisão, com justificativa explícita de *quando* ela é necessária frente a logs assinados ou bancos append-only, e a delimitação do que o protótipo atual ainda não implementa; e
- uma avaliação *offline* reproduzível (código, dados, modelos e hiperparâmetros publicados) do motor de risco sobre dados sintéticos.

O restante do artigo organiza-se assim. A Seção II revisa os trabalhos correlatos. A Seção III descreve a arquitetura proposta; a Seção IV, o motor de IA; e a Seção V, a camada de auditoria em blockchain. A Seção VI apresenta a metodologia de avaliação e a Seção VII, os resultados. A Seção VIII conclui.

II. TRABALHOS CORRELATOS

Biometria comportamental. A autenticação contínua a partir de padrões de interação está bem estabelecida. O TypeNet [11] e o TypeFormer [12] identificam usuários pela dinâmica de digitação com baixas taxas de erro, e o Touchalytics [13] mostra que padrões de toque discriminam usuários em dispositivos móveis. Esses trabalhos confirmam o poder discriminativo do comportamento do usuário, mas concentram-se em uma única modalidade biométrica e não tratam da auditoria imutável das decisões. Surveys recentes de autenticação contínua baseada em sensores [9] corroboram que sinais comportamentais generalizam por diversas modalidades, ao mesmo tempo em que apontam desafios em aberto de robustez, envelhecimento de template e implantação real — desafios que reforçam a fusão do comportamento com outros sinais contextuais em vez da dependência de uma única modalidade.

Sinais contextuais e de dispositivo. Além do comportamento, o contexto de dispositivo e rede de um login é, por

si só, discriminativo. Alaca e van Oorschot [7] classificam vinte e nove métodos de fingerprinting de dispositivo para reforçar a autenticação web, comparando-os por estabilidade, dificuldade de spoofing e distinguibilidade, e Andriamilanto *et al.* [8] mostram, em mais de quatro milhões de navegadores, que fingerprints de navegador carregam distinguibilidade e estabilidade suficientes para reforçar a autenticação. Freeman *et al.* [6] introduziram o primeiro modelo probabilístico público que classifica um login como normal ou suspeito a partir de sinais como IP de origem, geolocalização, configuração do navegador e hora do dia. Esses trabalhos validam sinais contextuais individuais, mas os tratam em grande parte de forma isolada e não acoplam a decisão resultante a um registro à prova de adulteração.

Autenticação baseada em risco. Wiefeling *et al.* [4] conduziram o primeiro estudo empírico de larga escala sobre RBA em serviços reais, e trabalhos posteriores [5] mostraram que os fatores de risco devem ser cuidadosamente ajustados por serviço. Nossa proposta segue essa linha, mas substitui heurísticas fixas — e os modelos de sinal único, pontuados estatisticamente, que as precederam [6] — por um ensemble de ML multissinal e adiciona uma camada de não repúdio.

Deteção de anomalias. O Isolation Forest [14] é referência para detecção não supervisionada de outliers em alta dimensionalidade, e modelos supervisionados e profundos [16] o complementam quando há rótulos; Killourhy e Maxion [15] estabeleceram um marco metodológico para a detecção de anomalias em dinâmica de digitação. Combinamos ambas as naturezas — não supervisionada e supervisionada — em um ensemble.

Blockchain para auditoria. Embora a auditoria de logs baseada em blockchain venha sendo investigada, a maioria das abordagens trata o registro de eventos de forma *desacoplada* do mecanismo de decisão. Sistemas como o BlockAudit [10] demonstram trilhas de auditoria escaláveis e à prova de adulteração em blockchain, mas os eventos registrados originam-se em aplicações externas à camada de registro, de modo que o registro atesta *que* um evento ocorreu sem vinculá-lo ao raciocínio que o produziu. O diferencial pretendido por este trabalho é integrar, em um único fluxo, a decisão adaptativa por IA e o seu registro imutável em rede permissionada, de modo que cada entrada armazenada carregue os próprios critérios e o escore que justificaram a ação. A Tabela I sintetiza trabalhos representativos: nenhuma linha de pesquisa reúne simultaneamente (i) a fusão de múltiplos sinais contextuais e comportamentais, (ii) a decisão adaptativa por ensemble e (iii) a auditoria imutável acoplada à decisão.

III. ARQUITETURA PROPOSTA

A arquitetura articula microsserviços, gestão federada de identidade, análise de risco por IA e registro imutável em blockchain, seguindo os princípios de segurança por desenho e verificação contínua do Zero Trust [3], [20]. Em vez de uma decisão binária no momento do login, o modelo adota uma perspectiva contínua e orientada a risco. Organiza-se em cinco camadas integradas (Fig. 1):

Tabela I
POSICIONAMENTO FRENTE A TRABALHOS CORRELATOS
REPRESENTATIVOS

Trabalho	Sinais	Adapt.	Audit.	Dados
TypeNet [11]	Digitação	✓	—	Real
Touchalytics [13]	Toque	✓	—	Real
Freeman [6]	IP/geo/UA	Parc.	—	Real
Alaca [7]	Fp. disp.	—	—	—
Andriam. [8]	Fp. nav.	—	—	Real
RBA [4]	IP/contexto	Parc.	—	Real
Iso. Forest [14]	Genérico	N. sup.	—	—
BlockAudit [10]	Logs	—	✓	—
Este trab.	14	Ens.	Proj.	Sint.
	ctx.+comp.			

Adapt.: decisão adaptativa/aprendida (Parc.: parcial; N. sup.: não supervisionada; Ens.: ensemble). *Audit.*: auditoria imutável acoplada à decisão (Proj.: projetada, ainda não implementada).

- 1) **Aplicação Modular.** Serviços independentes (Spring Boot) e front end Angular expõem APIs REST autenticadas.
- 2) **Identidade e Acesso.** Autenticação federada via Keycloak (OAuth2 / OpenID Connect), emissão de JWT e suporte a MFA.
- 3) **Inteligência Contextual.** Extração dos quatorze critérios comportamentais e cálculo do escore de risco pelo ensemble.
- 4) **Decisão Adaptativa.** Aplicação dos limiares de risco, resultando em *permitir*, *reforçar com MFA* ou *bloquear*.
- 5) **Registro Imutável e Auditoria.** Persistência de cada decisão em blockchain permissionada, garantindo rastreabilidade e não repúdio.

O fluxo operacional é uma cadeia decisória encadeada: a tentativa de login dispara a extração dos critérios contextuais; o motor de IA calcula o escore de risco; os limiares de decisão são aplicados; o resultado é registrado na blockchain; e o sistema permite o acesso, exige MFA ou o bloqueia. A separação em camadas permite evoluir cada responsabilidade de forma independente e aplicar políticas de segurança específicas em cada nível.

Modelo de ameaças e racional de projeto. O sistema pressupõe um adversário que pode já deter credenciais válidas — obtidas por vazamento, phishing ou reutilização — e que pode tentar logins a partir de redes e dispositivos arbitrários, mas que não consegue forjar o consenso da rede permissionada nem observar o estado privado dos modelos de risco. Sob esse modelo, as camadas tratam preocupações complementares: a C2 estabelece *quem* alega autenticar-se, a C3 estima *quão provável* é que a alegação seja legítima dado o contexto, a C4 converte a estimativa em uma ação proporcional e a C5 torna a ação *prestável de contas*. A faixa intermediária pressupõe que o adversário não detém o segundo fator; um adversário com credenciais e acesso ao segundo fator (p.ex., por phishing em tempo real) só é contido pela faixa de bloqueio, razão pela qual a proporção de ataques que cai em cada faixa precisa ser reportada, e não apenas o desempenho binário. Desacoplar

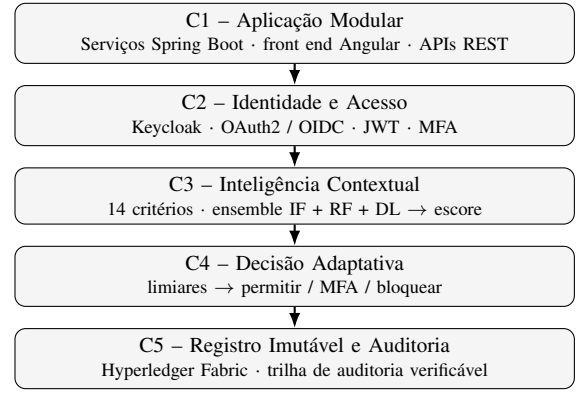


Figura 1. Arquitetura em cinco camadas do sistema proposto.

a estimativa (C3) da aplicação (C4) é deliberado: os limiares de risco podem ser recalibrados, e os modelos reentrenados, sem tocar no provedor de identidade, e a camada de auditoria permanece agnóstica aos aprendizes específicos em uso. Como cada decisão é registrada junto com sua justificativa — o hash dos critérios de entrada e o escore que o produziu —, um auditor pode reproduzir posteriormente qualquer decisão e verificar que a ação registrada corresponde à política vigente naquele momento, sem precisar confiar nos próprios logs do operador. É esse acoplamento estreito entre *decidir* e *registrar* que distingue a proposta de pipelines que registram eventos depois, e separadamente, da decisão.

Estado do protótipo. A arquitetura acima é o alvo do projeto. O protótipo público (Spring Boot + Angular) implementa até agora: login com senha e JWT próprios (a integração com o Keycloak existe como perfil de configuração opcional, não utilizado na implantação atual); MFA por TOTP; uma versão em Java dos três modelos, treinada na inicialização; e a persistência de cada decisão em uma tabela relacional (PostgreSQL) com um encadeamento de hashes. Três divergências em relação ao texto são explicitadas: (i) os modelos avaliados na Seção VII são os do pipeline *offline* em Python, e não os do protótipo Java, que usa outro conjunto de quatorze atributos; (ii) no protótipo, o escore do ensemble ainda é combinado a um escore de confiança ($T = 0,4H + 0,3(1 - A) + 0,2R + 0,1X$, com H histórico de sucesso, A risco da IA, R comportamento recente e X fatores externos), e o MFA é exigido quando $T < 0,5$, sem faixa de bloqueio; (iii) a camada C5 não está conectada a uma rede Fabric: o serviço correspondente é um simulador, e a verificação de integridade da cadeia de hashes ainda não é funcional. Alinhar o protótipo à Eq. (1) e às três faixas é o próximo passo de implementação.

IV. MOTOR DE DECISÃO POR IA

Ensemble. O motor de risco combina três aprendizes complementares. O *Isolation Forest* [14] atua como primeiro nível de análise, isolando outliers no espaço multidimensional de critérios com poucas partições aleatórias; contribui com 40% do peso final. O *Random Forest* contribui com 30%,

capturando relações não lineares entre os critérios e mantendo-se interpretável. Uma *rede neural multicamada* [16] contribui com os 30% restantes, com camada de entrada de 14 neurônios, duas camadas ocultas (64 e 32 unidades, ativações ReLU, otimizador Adam, sem dropout) e saída logística. O escore final é a média ponderada

$$S = 0,4 S_{IF} + 0,3 S_{RF} + 0,3 S_{DL}, \quad (1)$$

em que cada componente retorna um valor em $[0, 1]$ (0: normal, 1: altamente anômalo). A combinação de aprendizes não supervisionados e supervisionados visa cobrir tanto desvios inéditos (sem rótulo) quanto padrões de fraude conhecidos; a contribuição de cada modelo é medida na Seção VII.

Crítérios. Cada tentativa é representada por quatorze critérios em quatro famílias: *temporais* (hora do acesso, dia da semana, intervalo desde o último login, frequência em 24 h); *geográficos/rede* (distância geodésica do local habitual, tipo de rede, ASN, velocidade de deslocamento impossível); *dispositivo/navegador* (fingerprint do navegador, sistema operacional, tipo de dispositivo, detecção de automação/headless); e *comportamento de sessão* (padrão de digitação e histórico de falhas recentes). Esses sinais visam credential stuffing, viagem impossível, sequestro de sessão, bots e desvios zero-day.

Limiares adaptativos. O escore é mapeado em três faixas de risco, cujos cortes (0,3 e 0,7) são parâmetros de projeto, e não valores calibrados: baixo risco ($S < 0,3$) permite o acesso sem etapas adicionais; risco moderado ($0,3 \leq S < 0,7$) aciona MFA; e alto risco ($S \geq 0,7$) bloqueia a tentativa, registra o evento na blockchain e notifica o administrador de segurança. A avaliação da Seção VII usa, além das faixas, um limiar binário único ($\tau = 0,54$, Seção VI), que cai dentro da faixa de MFA; por isso precisão, recall e FPR não descrevem, sozinhos, a liberação nem o bloqueio, e o desempenho por faixa é reportado à parte (Tabela V). Os três modelos são avaliados sequencialmente. Retreinamento periódico frente à deriva de conceito [17] e versionamento de modelos são requisitos de projeto ainda não implementados.

V. AUDITORIA BASEADA EM BLOCKCHAIN

Esta seção descreve o *projeto* da camada de auditoria; como explicado na Seção III, ela ainda não foi integrada a uma rede real, e sua avaliação é trabalho futuro. No projeto, cada decisão é registrada em uma rede permissionada baseada em Hyperledger Fabric [18], cujo controle de identidade e governança estruturada são adequados a ambientes corporativos e governamentais [19]. Para cada evento, o registro armazena o hash dos critérios de entrada, o escore de risco, a decisão (permitir, MFA ou bloquear) e o timestamp da transação, encadeado ao registro anterior de modo a formar uma cadeia cronológica de evidências.

A escolha do blockchain frente a mecanismos mais simples é justificada, e não presumida. Logs assinados digitalmente e bancos append-only já oferecem integridade e não repúdio por meio de assinaturas criptográficas, sendo suficientes quando existe uma autoridade central confiável que opera o registro. A diferença essencial de um blockchain permissionado *não*

está na assinatura em si, mas em não depender da confiança em um único custodiante: o registro é replicado e validado por consenso entre múltiplos participantes, tornando-se resistente à adulteração mesmo por administradores privilegiados do próprio sistema e permitindo verificação independente por auditores externos. Isso é determinante aqui, pois as decisões de acesso são tomadas de forma autônoma por modelos de IA e precisam ser auditáveis por terceiros (por exemplo, em fiscalizações de conformidade da LGPD [21]), cenário em que o operador, sozinho, não deve poder alterar a trilha de decisões. Reconhece-se o custo — maior complexidade operacional e menor throughput do que um banco append-only —, que se justifica justamente em cenários multipartes e regulados, delimitando o escopo em que o blockchain é efetivamente necessário. Esse custo ainda não foi medido; a avaliação planejada exige uma rede com ao menos duas organizações e mede a latência de *commit*, a vazão sob carga e a detecção de uma adulteração deliberada por um administrador de uma das organizações. Enquanto isso não for feito, o registro relacional do protótipo continua sob controle de um único custodiante — exatamente o cenário que esta seção considera insuficiente.

VI. METODOLOGIA DE AVALIAÇÃO

Dados e rotulagem. Diante da ausência de bases públicas rotuladas para autenticação contextual, construiu-se um conjunto de dados sintéticos com 50.000 registros de login,¹ com proporção de 95% de acessos legítimos e 5% suspeitos, fixada como hipótese de trabalho (não se trata de uma distribuição medida em produção). Cada registro contém os quatorze critérios da Seção IV. *O rótulo de cada registro é o ramo do gerador que o produziu* (legítimo ou perturbado); não houve revisão manual por especialistas. Todas as distribuições são constantes escolhidas pelos autores para representar um uso corporativo plausível, e não parâmetros estimados a partir de dados reais: a hora de acesso é uma gaussiana ($\mu = 13$ h, $\sigma = 3,2$ h) truncada em $[0, 23]$ — tratada como variável linear, sem codificação circular —, o intervalo entre logins segue uma exponencial, a frequência em 24h uma Poisson e a distância geodésica uma meia-normal; os escores de fingerprint do navegador e de similaridade de digitação são gaussianas de média alta truncadas em $[0, 1]$, e os indicadores de dispositivo, sistema operacional, ASN e tipo de rede são variáveis categóricas com frequências fixadas no gerador. Os registros suspeitos são obtidos perturbando *de dois a quatro* critérios, escolhidos ao acaso, de um perfil legítimo para faixas anômalas (horário de madrugada, fim de semana, rajada de logins, distância e velocidade de deslocamento impossíveis, rede ou ASN atípicos, sistema operacional ou dispositivo desconhecidos, fingerprint e digitação divergentes, automação, falhas recentes). Cerca de 5% dos registros legítimos recebem uma perturbação em *um* critério, sorteada *das mesmas faixas* usadas para os ataques; é essa escolha que gera os falsos positivos. Por fim, adiciona-se a todos os critérios ruído gaussiano

¹Conjunto de dados (CSV rotulado, modelos treinados e métricas): <https://github.com/jgbcientista/gestao-autonomo/tree/main/docs/artefatos-modelos>

com desvio de 0,30 vezes o desvio-padrão da coluna. Como o ruído é aplicado também às variáveis categóricas e às não negativas, o conjunto contém valores fisicamente implausíveis (p. ex., ASN = 0,94 ou velocidade de deslocamento negativa); registramos essa limitação do gerador em vez de ocultá-la, e sua correção faz parte dos trabalhos futuros. Por se tratar de dados sintéticos, não há coleta de informações pessoais identificáveis nesta fase; a evolução para dados reais seguirá os princípios de minimização e anonimização exigidos pela LGPD [21].

Protocolo. O conjunto foi particionado de forma estratificada em 70% para treinamento e 30% para teste. O normalizador (padronização) e a normalização min-max do escore da Isolation Forest são ajustados apenas no treino. Os hiperparâmetros (Tabela II) foram fixados *a priori*, sem busca; o único parâmetro ajustado é o limiar de decisão, escolhido na grade $\{0,20, 0,21, \dots, 0,80\}$ como o que maximiza o F1 no treino ($\tau = 0,54$) e aplicado sem alteração ao teste. Para estimar a variabilidade, executou-se uma validação cruzada estratificada de 5 folds *apenas sobre a partição de treino*, em que o normalizador, os modelos e o limiar são reajustados dentro de cada fold; a partição de teste não participa. O desempenho foi medido por precisão, recall, F1-score, taxa de falsos positivos (FPR), AUC-ROC, AUC da curva precisão-recall (PR-AUC, mais informativa sob desbalanceamento) e latência de inferência. Para a decisão em três faixas, definem-se a *taxa de atrito* (fração de acessos legítimos que recebem MFA ou bloqueio) e a *taxa de passagem silenciosa* (fração de ataques liberados sem nenhum desafio). As sementes aleatórias foram fixadas.

Análises adicionais. Com o mesmo pipeline, avaliam-se ainda: (i) cada modelo isolado, com limiar próprio escolhido no treino; (ii) as 66 combinações de pesos em passos de 0,1 (análise de sensibilidade, não de seleção); (iii) proporções de ataques de 1%, 2%, 5%, 10% e 20%; (iv) uma variante do gerador sem ruído nas variáveis categóricas e de contagem e com truncamento das contínuas não negativas, que elimina os valores implausíveis; e (v) um atacante que conhece os quatorze critérios e substitui os que controla por valores sorteados da distribuição legítima, em quatro níveis cumulativos: horário e ritmo de tentativas; rede, ASN e localização (proxy residencial próximo à vítima); fingerprint, sistema, dispositivo e automação (navegador anti-deteção); e padrão de digitação. Para permitir verificação independente, o código-fonte, os artefatos dos modelos treinados e os scripts que geram o conjunto de dados e reproduzem cada experimento estão abertamente disponíveis.²

Reprodutibilidade. Um único script de entrada regenera todo o pipeline de forma determinística a partir da semente fixa: o conjunto rotulado (50.000 registros com os quatorze critérios e o rótulo de classe), os três modelos treinados juntamente com o normalizador de atributos (serializados com `joblib`), a configuração do ensemble (pesos dos componentes, os limites de normalização do escore da Isolation

Tabela II
HIPERPARÂMETROS UTILIZADOS (FIXADOS A PRIORI)

Componente	Configuração
Pré-processamento	padronização (z-score) ajustada no treino
Isolation Forest	100 árvores; contaminação 0,05; escore <code>-score_samples</code> normalizado min-max pelo treino e truncado em $[0, 1]$
Random Forest	120 árvores; profundidade livre; <code>class_weight=balanced</code>
Rede neural (MLP)	camadas ocultas 64–32, ReLU, Adam, 220 iterações, sem dropout; saída logística
Ensemble	$0,4 S_{IF} + 0,3 S_{RF} + 0,3 S_{DL}$
Limiar	grade 0,20–0,80 (passo 0,01), máx. F1 no treino $\Rightarrow \tau = 0,54$
Dados	50.000 registros; 5% suspeitos; ruído $0,30\sigma$; semente 42

Forest e o limiar de decisão selecionado pelo melhor F1 de treinamento) e um arquivo de métricas legível por máquina contendo cada valor reportado na Seção VII. Reexecutar o script em um ambiente limpo reproduz as métricas reportadas; diferenças de versão do scikit-learn produzem apenas variações na terceira casa decimal (p. ex., F1 de 0,802 a 0,805), de modo que um revisor possa auditar todo o pipeline de ponta a ponta —da geração dos atributos brutos ao limiar de decisão final— sem acesso a quaisquer dados privados ou pessoalmente identificáveis. Esse empacotamento é o que transforma a descrição de “cerca de 50.000 registros” em um artefato que um terceiro pode regenerar, inspecionar e estender.

Baselines. A Tabela III confronta a proposta com baselines representativos da literatura e da prática. Os valores dos baselines provêm da literatura citada e não foram reexecutados aqui; a comparação é, portanto, qualitativa quanto às capacidades de cada abordagem. Os três eixos de comparação não são arbitrários; decorrem dos requisitos que a literatura impõe à autenticação moderna. A *sensibilidade ao contexto* (Ctx.) reflete a recomendação do NIST e do modelo Zero Trust de que a verificação seja condicionada aos sinais de cada tentativa, e não apenas à credencial [1], [3], propriedade que estudos empíricos de autenticação baseada em risco apontam como decisiva na prática [4], [6]. A *adaptabilidade* (Adapt.) expressa se a resposta é proporcional ao risco estimado — princípio central da autenticação baseada em risco [1], [4], [5] — em vez de uma regra fixa. A *auditabilidade* (Audit.) trata da prestação de contas de decisões automatizadas sobre dados pessoais, exigência explicitada por regulações como a LGPD [21] e, de modo mais amplo, pela necessidade de verificação independente quando o acesso é delegado a modelos autônomos. Em conjunto, esses eixos cobrem as duas propriedades que um sistema de autenticação contextual precisa satisfazer simultaneamente — decidir corretamente e ser verificável —, enquanto a coluna *principal limitação* indica onde cada baseline falha em ao menos uma delas.

²<https://github.com/jgbcientista/gestao-autonomo>

Tabela III
COMPARAÇÃO COM ABORDAGENS DE REFERÊNCIA

Abordagem	Ctx.	Adapt.	Audit.	Limitação principal
Senha + 2FA estático	—	—	—	Ignora contexto; phishing/SIM swap
RBA por IP [4]	Parc.	Heur.	—	Feature única; ajuste manual
Escore estatístico [6]	✓	Est.	—	Poucos sinais; sem auditoria
Keystroke isolado [15]	✓	—	—	Offline, fator único (EER $\approx 9,6\%$)
Proposta	✓	Ens.	Proj.	Dados sintéticos; auditoria em projeto

Ctx.: usa contexto do login; *Adapt.*: decisão adaptativa (Heur.: heurística; Est.: estatística; Ens.: ensemble); *Audit.*: auditoria imutável acoplada à decisão (Proj.: projetada).

Tabela IV
DESEMPENHO DO ENSEMBLE NO CONJUNTO DE TESTE

Métrica	Valor	Métrica	Valor
Acurácia	98,1%	F1-score	80,2%
Precisão	83,0%	AUC-ROC	0,99
Recall	77,6%	Taxa falsos pos.	0,8%
F1 (CV 5 folds no treino)	80,3% $\pm$ 1,3%		
AUC (CV 5 folds no treino)	0,990 $\pm$ 0,002		
Latência do ensemble (<i>offline</i>)	≈ 33 ms/req.		

VII. RESULTADOS E DISCUSSÃO

Sobre o conjunto de teste (30% dos dados, não vistos durante o treinamento), o ensemble alcançou acurácia de 98,1%, precisão de 83,0% e recall de 77,6% na detecção de acessos suspeitos, com F1-score de 80,2% e AUC-ROC de 0,99, indicando forte capacidade de ordenação entre acessos legítimos e suspeitos. A taxa de falsos positivos manteve-se baixa, em 0,8%, fator relevante para a usabilidade. A validação cruzada restrita ao treino confirma a ordem de grandeza (F1 80,3% $\pm$ 1,3%; AUC 0,990 $\pm$ 0,002), com limiares entre 0,42 e 0,56 conforme o fold. A matriz de confusão no teste é TN=14.131, FP=119, FN=168, TP=582. A Tabela IV resume esses números.

Decisão em três faixas. A Tabela V aplica as faixas 0,3/0,7 ao escore do teste. Entre os acessos legítimos, 97,3% são liberados sem desafio (taxa de atrito de 2,7%) e apenas 0,1% são bloqueados. Entre os ataques, 62,5% são bloqueados, 30,1% recebem MFA e 7,3% passam silenciosamente. Como a faixa de MFA só contém um adversário que não detém o segundo fator (Seção III), a proteção efetiva contra quem tem credenciais e segundo fator é a fração bloqueada, e não o recall binário.

Contribuição de cada modelo. A Tabela VI compara o ensemble a cada modelo treinado isoladamente no mesmo pipeline. O ensemble ganha cerca de 3 pontos de F1 sobre

Tabela V
DECISÃO EM TRÊS FAIXAS NO CONJUNTO DE TESTE

Classe real	Permitir ($S < 0,3$)	MFA	Bloquear ($S \geq 0,7$)
Legítimo	97,3%	2,6%	0,1%
Suspeito	7,3%	30,1%	62,5%
Taxa de atrito: 2,7%		Taxa de passagem silenciosa: 7,3%	

Tabela VI
ENSEMBLE VERSUS MODELOS ISOLADOS (TESTE)

Modelo	τ	Prec.	Rec.	F1	FPR	PR-AUC
Isolation Forest	0,45	0,763	0,772	0,767	1,26%	0,855
Random Forest	0,60	0,779	0,771	0,775	1,15%	0,857
Rede neural	0,48	0,757	0,792	0,774	1,34%	0,860
Ensemble	0,54	0,830	0,776	0,802	0,84%	0,903

o melhor modelo isolado (0,802 contra 0,775 da Random Forest), reduz a FPR de 1,15% para 0,84% e eleva a PR-AUC de 0,86 para 0,90. Os pesos 0,4/0,3/0,3, porém, não foram otimizados: nas 66 combinações avaliadas, o F1 no teste varia de 0,767 (só Isolation Forest) a 0,820, e a configuração adotada fica em 19.º lugar. As melhores combinações atribuem 0,6–0,8 à Isolation Forest e pouco ou nenhum peso à rede neural. Escolher os pesos por esse resultado seria ajustar ao teste; a seleção correta, em uma partição de validação, fica para a próxima etapa.

Sensibilidade à proporção de ataques e ao gerador. A Tabela VII repete o experimento para outras proporções. A AUC permanece em 0,99, mas as métricas dependentes da prevalência mudam bastante: com 1% de ataques, o F1 cai para 0,63 e a passagem silenciosa sobe para 24,0%, porque a Isolation Forest (contaminação igual à proporção) e o limiar escolhido por F1 passam a favorecer a classe majoritária. Em produção, em que ataques tendem a ser mais raros que 5%, esse é o cenário relevante. Já a correção do ruído do gerador (item (iv) das análises adicionais) quase não altera os resultados (F1 0,809, AUC 0,992, passagem silenciosa 6,9%), o que indica que os valores implausíveis não inflavam as métricas.

Evasão adversarial. A Tabela VIII mostra o efeito de um atacante que conhece os critérios. Imitar apenas o horário e o ritmo das tentativas — algo trivial — já reduz o recall de 77,6% para 50,7% e eleva a passagem silenciosa de 7,3% para 28,4%. Com um proxy residencial próximo à vítima, o recall cai para 18,0% e 64,4% dos ataques passam sem desafio; com um navegador anti-deteção, praticamente todos passam. Esse resultado é, em parte, consequência do gerador: os ataques sintéticos *são definidos* como desvios nesses critérios, de modo que removê-los apaga o sinal. Mas ele também expõe um limite real da abordagem: a maioria dos quatorze critérios é controlável pelo adversário, e só o padrão de digitação e o histórico da conta resistem a um atacante informado. Critérios difíceis de forjar e defesas contra evasão são, portanto,

Tabela VII
SENSIBILIDADE À PROPORÇÃO DE ATAQUES

Ataques	F1	AUC	PR-AUC	Atrito	Pass. silenc.
1%	0,632	0,989	0,718	0,8%	24,0%
2%	0,720	0,991	0,809	1,1%	16,7%
5%	0,802	0,992	0,903	2,7%	7,3%
10%	0,869	0,992	0,944	3,1%	6,4%
20%	0,917	0,993	0,976	4,2%	3,7%

Tabela VIII
EVASÃO POR ATACANTE QUE CONHECE OS CRITÉRIOS (ATAQUES DO TESTE)

Crítérios imitados (cumulativo)	Recall	Permitir	MFA	Bloquear
Nenhum	77,6%	7,3%	30,1%	62,5%
+ horário e ritmo	50,7%	28,4%	33,1%	38,5%
+ rede, ASN, local (proxy)	18,0%	64,4%	25,3%	10,3%
+ fingerprint, SO, disp., autenticação	2,9%	91,1%	8,0%	0,9%
+ digitação (todos)	0,3%	98,1%	1,9%	0,0%

Recall no limiar binário $\tau = 0,54$; demais colunas com as faixas 0,3/0,7.

requisito, e não refinamento.

A latência foi medida apenas no pipeline *offline* (scikit-learn, uma amostra por chamada, mediana de 300 chamadas): 4,0 ms para a Isolation Forest, 29,2 ms para a Random Forest e 0,05 ms para a rede neural, executadas em sequência, totalizando cerca de 33 ms — valor dependente da máquina e dominado pela Random Forest. Não foram medidos a latência do fluxo completo de login, o custo do registro de auditoria nem a vazão; esses números dependem da integração descrita na Seção V e ficam para a próxima etapa.

Discussão. Os resultados parciais são promissores e sugerem a viabilidade técnica da abordagem; contudo, por decorrerem de dados sintéticos e de uma fase preliminar, não permitem ainda confirmar a hipótese central de forma conclusiva. Uma comparação rigorosa com os baselines e a validação com dados reais permanecem necessárias antes de qualquer afirmação quantitativa de superioridade. Ainda assim, em ambiente controlado, o ensemble separou os registros perturbados dos legítimos com AUC de 0,99, o que indica que os critérios escolhidos carregam sinal quando os ataques se manifestam nas faixas modeladas pelo gerador — ressalva que a análise de evasão torna concreta. Nenhuma afirmação sobre resistência à adulteração é feita nesta versão, pois a camada de auditoria não foi avaliada.

Análise de erros e compromissos. O limiar de decisão não é fixado a priori, mas selecionado como o valor que maximiza o F1-score na partição de treinamento, o que torna o ponto de operação explícito e ajustável por implantação: reduzi-lo aumenta o recall ao custo de mais desafios de step-up, ao passo que elevá-lo favorece uma experiência sem atrito ao risco de deixar escapar ataques limítrofes. No ponto escolhido, a matriz de confusão no conjunto de teste é dominada por verdadeiros

negativos, e os erros residuais concentram-se na fronteira entre acessos legítimos levemente anômalos e acessos suspeitos de baixa intensidade — exatamente a região que o modelo de ruído foi projetado para tornar ambígua. Isso explica tanto o F1 abaixo de 90% quanto a baixa taxa de falsos positivos: o ensemble é conservador, preferindo uma detecção perdida ocasional a penalizar usuários legítimos, viés apropriado a um front-end de autenticação, em que o atrito de usabilidade tem custo direto de negócio. Os três modelos contribuem com visões complementares — a Isolation Forest sinaliza combinações de atributos globalmente raras sem rótulos, enquanto a Random Forest e a rede neural exploram a fronteira de decisão rotulada. Evitamos deliberadamente ler esses números como evidência de superioridade sobre os baselines da Tabela III: os baselines não foram reexecutados sobre os mesmos dados, e o gerador sintético, por mais cuidadosamente calibrado, não captura toda a diversidade adversarial do tráfego de produção. Essas observações enquadram o experimento como um estudo de viabilidade cujo próximo passo é a validação sobre logs reais e não repudiáveis coletados sob a própria arquitetura aqui proposta.

Limitações e ameaças à validade. Quatro limitações delimitam o alcance das conclusões. Primeiro, a validade externa é restringida pelo uso de dados sintéticos: embora o processo gerador reproduza distribuições plausíveis de uso corporativo, ele não captura a cauda longa de comportamentos legítimos atípicos nem a criatividade adversarial observada em tráfego real, de modo que as métricas relatadas devem ser lidas como um limite superior otimista e não como desempenho esperado em produção. Segundo, a validade de construção depende da rotulagem heurística: por derivarem das mesmas regras que descrevem os padrões de fraude, os rótulos podem introduzir uma circularidade em que o ensemble reaprende as fronteiras codificadas no próprio gerador — risco que apenas a rotulagem sobre incidentes reais, revisada por analistas, elimina por completo. Terceiro, a comparação com os baselines é deliberadamente qualitativa, pois estes não foram reexecutados sobre o mesmo conjunto de dados; afirmações quantitativas de superioridade permanecem, portanto, fora do escopo desta fase preliminar. Quarto, a robustez adversarial é baixa: como mostra a Tabela VIII, a maior parte dos critérios pode ser imitada por um atacante informado. Mitigamos parcialmente essas ameaças fixando as sementes aleatórias, publicando os hiperparâmetros e disponibilizando abertamente o código e os artefatos para inspeção independente; a superação plena, contudo, exige a coleta de logs reais sob a arquitetura proposta — registro que a camada de auditoria, uma vez implementada, deverá tornar verificável —, fechando o ciclo entre a avaliação metodológica e a operação efetiva do sistema.

VIII. CONSIDERAÇÕES FINAIS E TRABALHOS FUTUROS

Este artigo apresentou um sistema autônomo de autenticação contextual que combina uma decisão adaptativa por IA com o projeto de uma auditoria em blockchain permissionada. As contribuições são a arquitetura que funde quatorze sinais contextuais e comportamentais por meio de um ensemble, o

projeto da camada de auditoria acoplada à decisão, com justificativa explícita para o uso de blockchain, e uma avaliação *offline* reproduzível do motor de risco. Experimentos preliminares sobre dados sintéticos indicaram viabilidade técnica (98,1% de acurácia, 80,2% de F1-score, AUC de 0,99, latência de inferência de ≈ 33 ms; 7,3% de passagem silenciosa com as três faixas), e o ensemble superou cada modelo isolado; a análise de evasão, contudo, mostra que a maior parte dos critérios é controlável por um atacante informado. Isso constitui uma validação metodológica e não um substituto para a avaliação com dados reais. O próximo passo imediato é integrar uma rede Fabric real com ao menos duas organizações, medindo latência de *commit*, vazão e detecção de adulteração, e alinhar o protótipo à Eq. (1) e às três faixas. Como trabalhos futuros, pretende-se ainda substituir o conjunto sintético por dados reais ou semirreais coletados em ambiente controlado, selecionar pesos e limiares em partição de validação, incorporar critérios difíceis de forjar e defesas contra evasão, avaliar desempenho e escalabilidade sob carga realista e aprofundar a análise de segurança frente ao modelo de ameaças. Planeja-se ainda investigar a explicabilidade das decisões do ensemble — expondo, para cada bloqueio ou desafio de MFA, os critérios de maior contribuição ao escore de risco —, avaliar o comportamento do sistema sob deriva de conceito prolongada e ataques adversariais de evasão, e conduzir um estudo de usabilidade que quantifique o atrito percebido pelos usuários legítimos frente aos desafios adaptativos.

REFERÊNCIAS

- [1] National Institute of Standards and Technology, “Digital Identity Guidelines: Authentication and Lifecycle Management,” NIST SP 800-63B, 2017.
- [2] Verizon, “2024 Data Breach Investigations Report (DBIR),” Verizon Business, 2024.
- [3] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, “Zero Trust Architecture,” NIST SP 800-207, 2020.
- [4] S. Wiefeling, L. Lo Iacono, and M. Dürmuth, “Is This Really You? An Empirical Study on Risk-Based Authentication Applied in the Wild,” in *IFIP SEC*, 2019, pp. 134–148.
- [5] S. Wiefeling, P. R. Jørgensen, S. Thunem, and L. Lo Iacono, “Pump Up Password Security! Evaluating and Enhancing Risk-Based Authentication on a Real-World Large-Scale Online Service,” *ACM Trans. Priv. Secur.*, vol. 26, no. 1, 2023.
- [6] D. Freeman, S. Jain, M. Dürmuth, B. Biggio, and G. Giacinto, “Who Are You? A Statistical Approach to Measuring User Authenticity,” in *Proc. Netw. Distrib. Syst. Secur. Symp. (NDSS)*, 2016.
- [7] F. Alaca and P. C. van Oorschot, “Device Fingerprinting for Augmenting Web Authentication: Classification and Analysis of Methods,” in *Proc. 32nd Annu. Comput. Secur. Appl. Conf. (ACSAC)*, 2016, pp. 289–301.
- [8] N. Andriamilanto, T. Allard, G. Le Guelvouit, and A. Garel, “A Large-scale Empirical Analysis of Browser Fingerprints Properties for Web Authentication,” *ACM Trans. Web*, vol. 16, no. 1, pp. 1–62, 2021.
- [9] M. Abuhamad, A. Abusnaina, D. Nyang, and D. Mohaisen, “Sensor-Based Continuous Authentication of Smartphones’ Users Using Behavioral Biometrics: A Contemporary Survey,” *IEEE Internet Things J.*, vol. 8, no. 1, pp. 65–84, 2021.
- [10] A. Ahmad, M. Saad, and A. Mohaisen, “Secure and Transparent Audit Logs with BlockAudit,” *J. Netw. Comput. Appl.*, vol. 145, art. 102406, 2019.
- [11] A. Acien, A. Morales, R. Vera-Rodriguez, J. Fierrez, and J. V. Monaco, “TypeNet: Deep Learning Keystroke Biometrics,” *IEEE Trans. Biom. Behav. Identity Sci.*, vol. 4, no. 1, pp. 57–70, 2022.
- [12] G. Stragapede, P. Delgado-Santos, R. Tolosana, R. Vera-Rodriguez, R. Guest, and A. Morales, “TypeFormer: Transformers for Mobile Keystroke Biometrics,” *Neural Comput. Appl.*, vol. 36, pp. 18531–18545, 2024.
- [13] M. Frank, R. Biedert, E. Ma, I. Martinovic, and D. Song, “Touchalytics: On the Applicability of Touchscreen Input as a Behavioral Biometric for Continuous Authentication,” *IEEE Trans. Inf. Forensics Security*, vol. 8, no. 1, pp. 136–148, 2013.
- [14] F. T. Liu, K. M. Ting, and Z.-H. Zhou, “Isolation Forest,” in *IEEE Int. Conf. Data Mining (ICDM)*, 2008, pp. 413–422.
- [15] K. S. Killourhy and R. A. Maxion, “Comparing Anomaly-Detection Algorithms for Keystroke Dynamics,” in *IEEE/IFIP DSN*, 2009, pp. 125–134.
- [16] I. Goodfellow, Y. Bengio, and A. Courville, *Deep Learning*. Cambridge, MA: MIT Press, 2016.
- [17] J. Gama, I. Žliobaitė, A. Bifet, M. Pechenizkiy, and A. Bouchachia, “A Survey on Concept Drift Adaptation,” *ACM Comput. Surv.*, vol. 46, no. 4, pp. 1–37, 2014.
- [18] Hyperledger Foundation, “Hyperledger Fabric Documentation, v2.5,” Linux Foundation, 2024.
- [19] National Institute of Standards and Technology, “Blockchain Technology Overview,” NISTIR 8202, 2018.
- [20] National Institute of Standards and Technology, “Security and Privacy Controls for Information Systems and Organizations,” NIST SP 800-53 Rev. 5, 2020.
- [21] Brasil, “Lei n. 13.709/2018 – Lei Geral de Proteção de Dados Pessoais (LGPD),” 2018.